



Методы защиты информации

Харунжева Елена Викторовна
к.п.н., доцент
kharunzhevaev@mail.ru

- 
- *К защищаемой* относится информация, являющаяся предметом собственности и подлежащая защите в соответствии с требованиями правовых документов или требованиями, выдвигаемыми собственником информации
 - *Угроза безопасности информации* – совокупность условий и факторов, создающих потенциальную или реально существующую опасность нарушения безопасности информации

ГОСТ Р 50922-2006 «Защита информации. Основные термины и определения» (утв. Приказом Ростехрегулирования от 27.12.2006 N 373-ст)

Системная классификация угроз

По видам угроз

По природе происхождения

По предпосылкам появления

По источникам угроз

По видам угроз

- **Угрозы физической целостности**
(уничтожение/искажение)
- **Угрозы логической структуре**
(искажение структуры)
- **Угрозы содержанию**
(несанкционированная модификация)
- **Угрозы конфиденциальности**
(несанкционированный доступ)
- **Угрозы права собственности**
(присвоение чужого права)



По природе происхождения

- **Случайные угрозы**
(ошибки, отказы, сбои, стихийные бедствия, побочные влияния)
- **Преднамеренные угрозы**
(злоумышленные действия)



По предпосылкам появления

- **Объективные угрозы**
(количественная недостаточность элементов системы, качественная недостаточность элементов системы)
- **Субъективные угрозы**
(разведорганы иностранных государств, промышленный шпионаж, уголовные элементы, недобросовестные сотрудники)



По источникам угроз

- **Люди**
(посторонние лица, пользователи, персонал)
- **Технические устройства**
(регистрации, передачи, хранения, обработки, выдачи информации)
- **Модели, алгоритмы, программы**
(общего назначения, прикладные, вспомогательные)
- **Технические схемы**
(ручные, интерактивные, внутремашинные, сетевые)
- **Внешняя среда**
(состояние атмосферы, побочные шумы и сигналы)



Методы защиты

- Криптографическая защита информации
- Защита информации от НСД
- Организационная защита информации
- Защита информации от утечки по техническим каналам



КРИПТОГРАФИЧЕСКАЯ ЗАЩИТА ИНФОРМАЦИИ

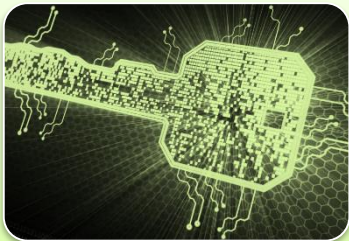
Способы тайной передачи информации



Абсолютно надежный, закрытый от посторонних, секретный канал связи



Стеганография (открытый общедоступный канал, сохранение в тайне самого факта передачи)



Криптография (открытый канал, зашифрованное сообщение)

Стеганография



Едет с грамотой гонец.
И приехал наконец.
А ткачиха с поварихой,
С сватьей бабой Бабарихой
Обождать его велят;
Допьяна гонца поят
И в суму его пустую
Суют грамоту другую...

А. С. Пушкин

Стеганография



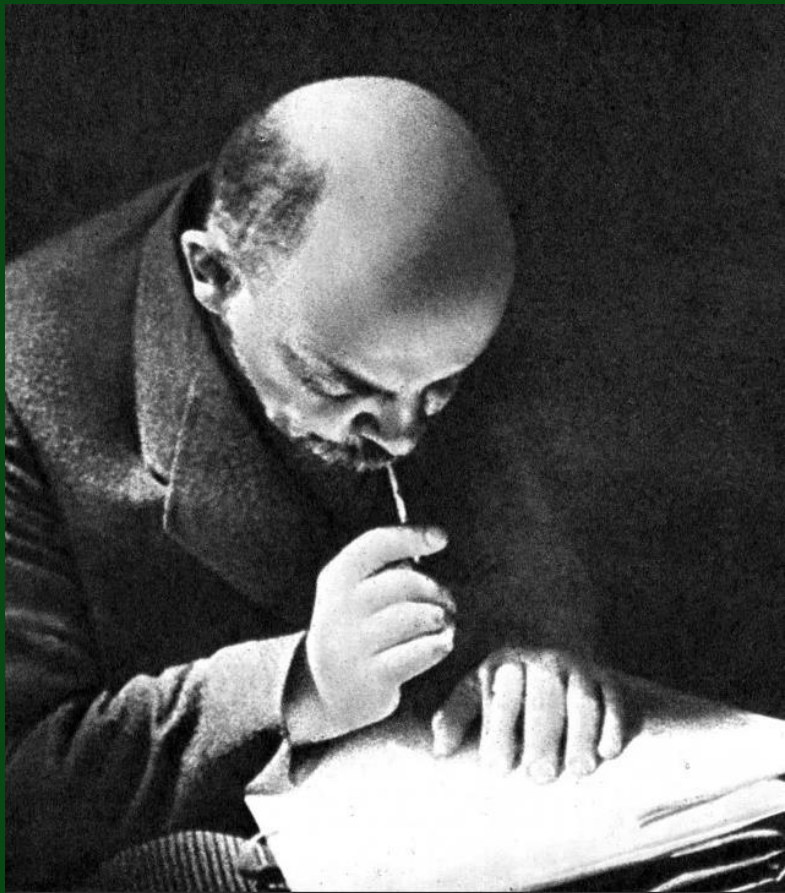
«Голова раба»

Стеганография

Микротекст



Стеганография



Невидимые чернила

Криптография

Криптография – наука о методах обеспечения невозможности прочтения информации посторонним, её целостности, подлинности авторства, а также невозможности отказа от авторства.

Шифр – система преобразования текста с секретом (ключом) для обеспечения секретности передаваемой информации.

Шифрование информации – обратимое преобразование открытого (исходного) текста на основе секретного алгоритма или ключа в закрытый, зашифрованный текст

Этапы развития криптографии:

- 1. Моноалфавитные шифры**
(3 тыс. до н. э. – IX–XV вв.)
- 2. Полиалфавитные шифры**
(IX–XV вв. – начало XX в.)
- 3. Использование электромеханических шифровальных машин**
(начало XX в. – середина 70-х гг.)
- 4. Криптография с открытым ключом**
(с середины 70-х гг. по настоящее время)

Простейшие криптографические преобразования

- Шифры перестановки (изменяется порядок букв в текстовом блоке):
 - шифрующие таблицы;
 - магический квадрат и др.
- Шифры замены (буквы открытого текста заменяют на другие буквы этого же или другого алфавита :
 - шифр Цезаря;
 - шифр Трисемуса;
 - «пляшущие человечки»;
 - биграммный шифр Плейфера и др.

Шифрующие таблицы

В качестве ключа в шифрующих таблицах используются:

- размер таблицы;
- слово или фраза, задающие перестановку;
- особенности структуры таблицы;
- способ записи сообщения в таблицу (по строкам, по столбцам, по спирали, по диагонали и так далее).

п	и	с	ь	м	о	п
р	и	б	у	д	е	т
в	ч	е	т	в	е	р
г	п	о	с	л	е	п
о	л	у	н	о	ч	и

ПИСЬМОПРИБУДЕТВЧЕТВЕРГПОСЛЕПОЛУНОЧИ (по строкам)



ПРВГОИИЧПЛСБЕОУЬУТСНМДВЛООЕЕЕЧПТРПИ (по столбцам)

Ключ – размер таблицы (количество столбцов)

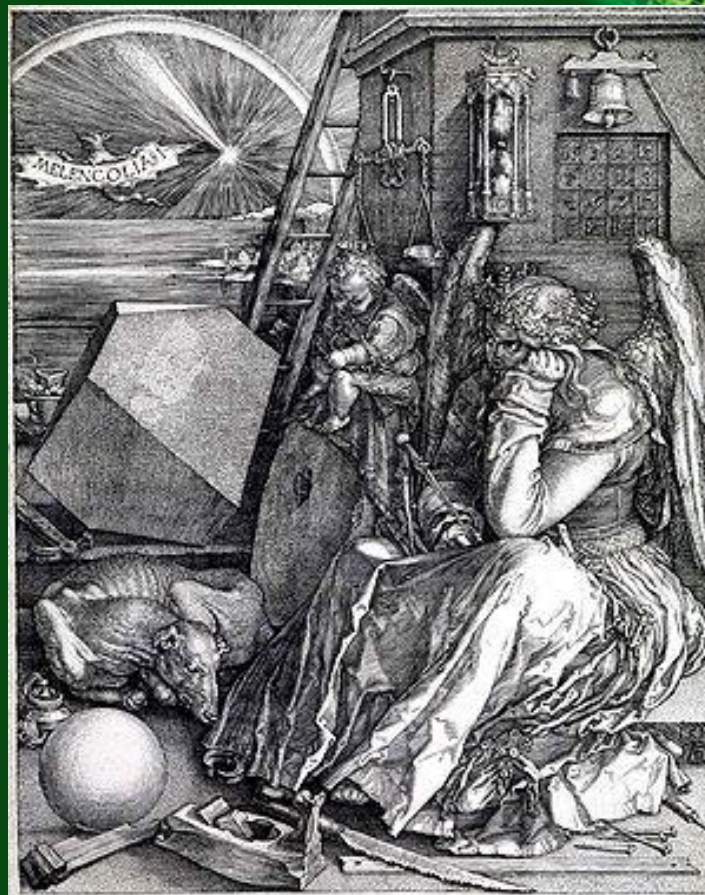
Магический квадрат

2		7		6	
	Л		А		И
9		5		1	
	А		П		О
4		3		8	
	М		И		Д

ЛАИАПОМИД



ОЛИМПИАДА



Шифр Цезаря



K=3

А	Б	В	Г	Д	Е	Ё	Ж	З	И	Й	К	Л	М	Н	О	П	Р	С	Т	У	Ф	Х	Ц	Ч	Ш	Щ	Ъ	Ы	Ь	Э	Ю	Я
↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	
Г	Д	Е	Ё	Ж	З	И	Й	К	Л	М	Н	О	П	Р	С	Т	У	Ф	Х	Ц	Ч	Ш	Щ	Ъ	Ы	Ь	Э	Ю	Я	А	Б	В

K=6

А	Б	В	Г	Д	Е	Ё	Ж	З	И	Й	К	Л	М	Н	О	П	Р	С	Т	У	Ф	Х	Ц	Ч	Ш	Щ	Ъ	Ы	Ь	Э	Ю	Я
↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓
Ё	Ж	З	И	Й	К	Л	М	Н	О	П	Р	С	Т	У	Ф	Х	Ц	Ч	Ш	Щ	Ъ	Ы	Ь	Э	Ю	Я	А	Б	В	Г	Д	Е

В ЛЕСУ РОДИЛАСЬ ЁЛОЧКА

Е ОЗФЦ УСЖЛОГФЯ ИОСЪНГ (K=3)

З СКЧЩ ЦФЙОСЁЧВ ЛСФЭРЁ (K=6)

Шифр Трисемуса

Ключ – любое слово или фраза (ХАРУНЖЕВА)

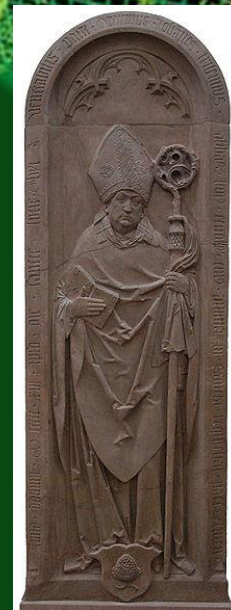
Размер таблицы для русского алфавита – 8x4

Заполнение таблицы:

ключевое слово без повторяющихся букв,

остальные буквы алфавита без буквы Ё

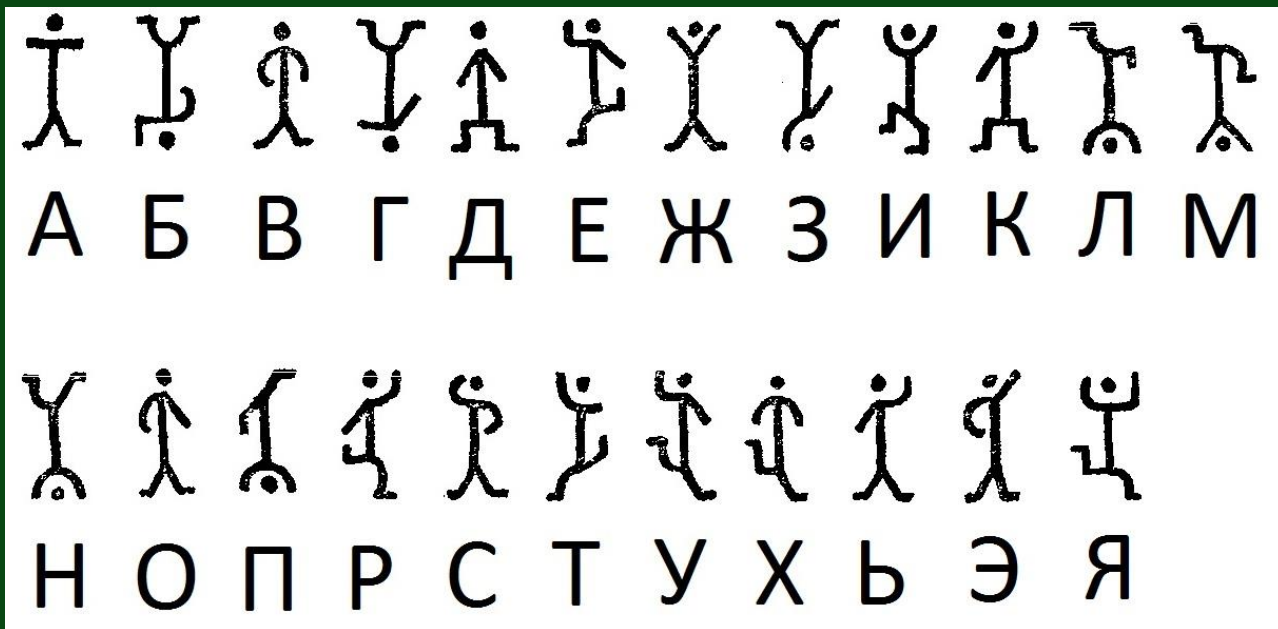
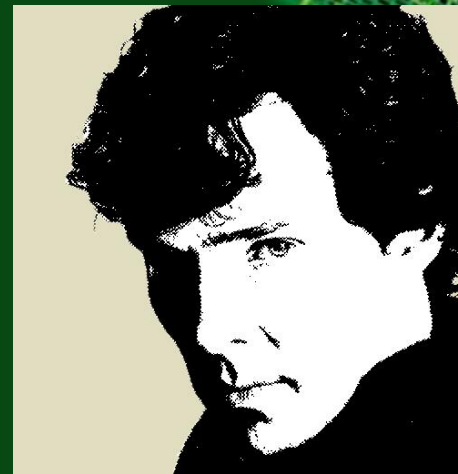
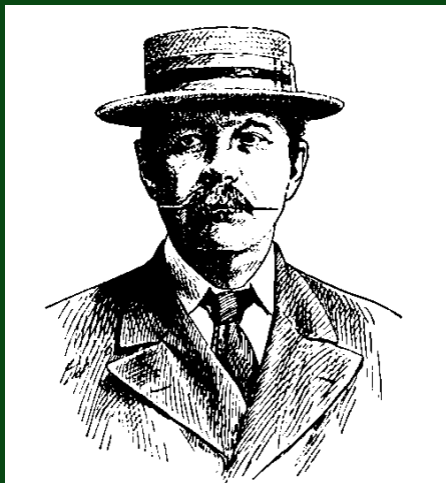
Шифрование – замена буквы на расположенную
ниже



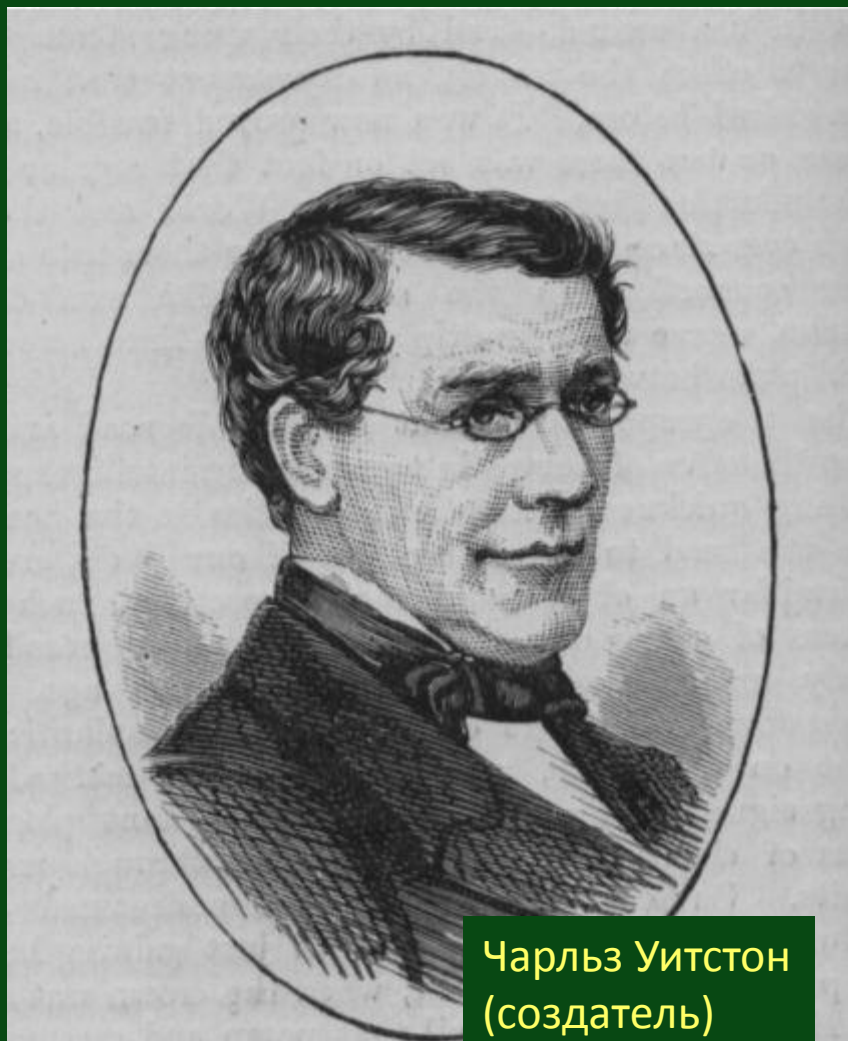
Х	А	Р	У	Н	Ж	Е	В
Б	Г	Д	З	И	Й	К	Л
М	О	П	С	Т	Ф	Ц	Ч
Ш	Щ	Ъ	Ы	Ь	Э	Ю	Я

ВЯТКА → ЛВЬЦГ

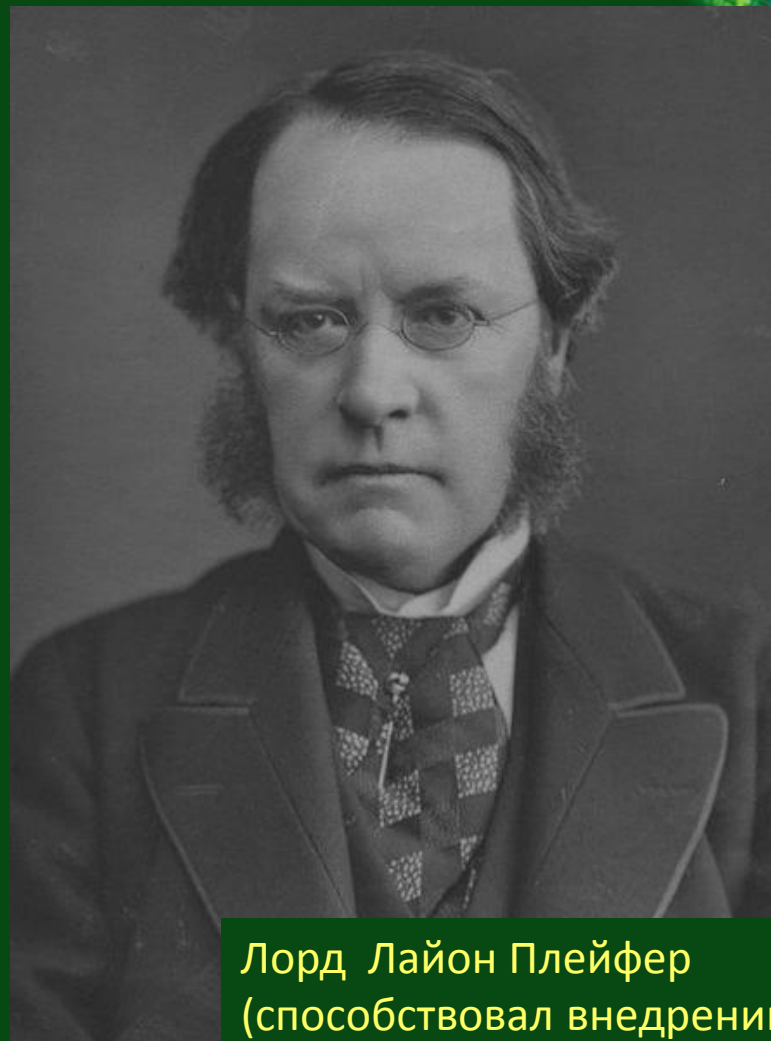
«Пляшущие человечки»



Биграммный шифр Плейфера



Чарльз Уитстон
(создатель)



Лорд Лайон Плейфер
(способствовал внедрению
в практику)

Биграммный шифр Плейфера

Х	А	Р	У	Н	Ж	Е	В
Б	Г	Д	З	И	Й	К	Л
М	О	П	С	Т	Ф	Ц	Ч
Ш	Щ	Ъ	Ы	Ь	Э	Ю	Я

1. БИ → ГЙ, АВ → РХ

2. УС → ЗЫ, ЯЛ → ВЧ

3. БФ → ЙМ, ЧК → ЦЛ

ШИ ФР ПЛ ЕЙ ФЕ РА

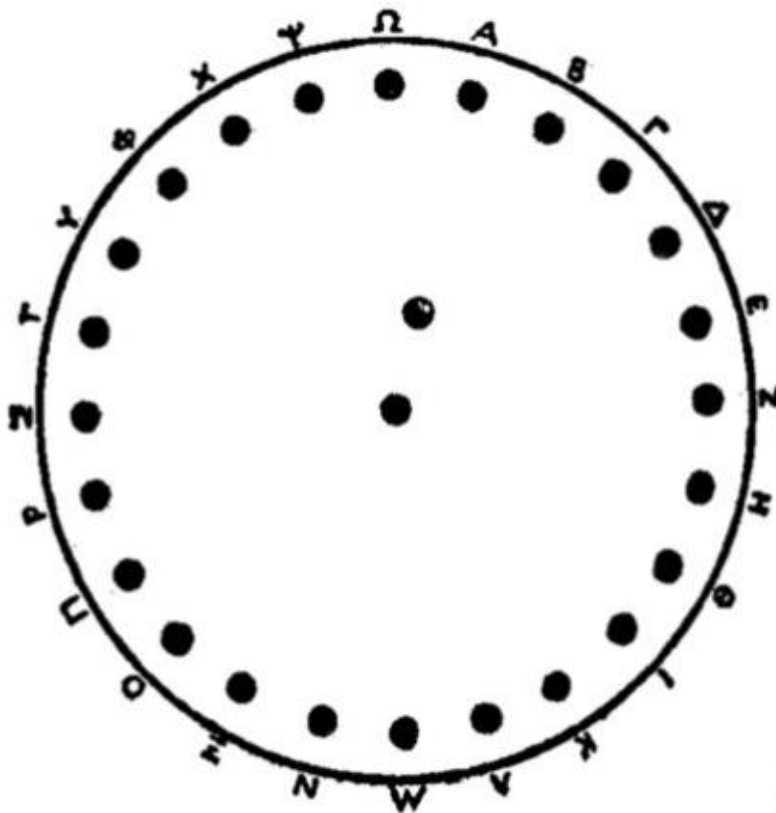


ЬБ ПЖ ЧД ЖК ЦЖ УР

Внимание!

Расшифровывание в случаях 1 и 2 производится в обратном порядке (сдвиг 1-влево, 2-вверх). В случае 3 шифрование и расшифровывание осуществляются одинаково

Шифровальные устройства



ДИСК ЭНЕЯ
Эней Тактик
IV век до н. э.



Шифровальные устройства



СЦИТАЛА

III век до н. э.

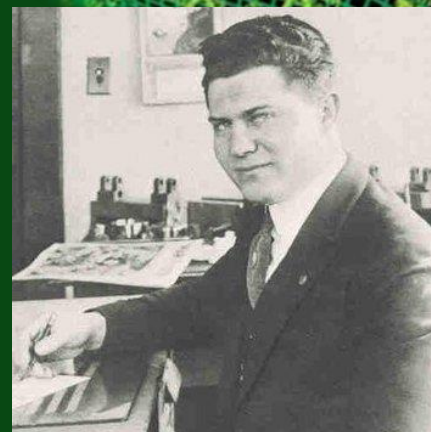
	Э	Т	О	Ш	И	
	Ф	Р	Д	Р	Е	
	В	Н	Е	Й	С	
	П	А	Р	Т	Ы	

ДИСК АЛЬБЕРТИ



Идея «двойного шифрования»

Шифровальные устройства



Эдвард Хеберн
(1869 — 1952)

ШИФРОВАЛЬНАЯ
МАШИНА ХЕБЕРНА
1915 г., США

Шифровальные устройства



ШИФРОВАЛЬНАЯ
МАШИНА
ENIGMA

Гуго Кох де Дельфтю
(Голландия)
1917 г.

Артур Шербиус
(Германия)
патент 1918 г.



ЭЛЕКТРОННАЯ ПОДПИСЬ КАК СОВРЕМЕННОЕ КРИПТОГРАФИЧЕСКОЕ СРЕДСТВО ЗАЩИТЫ ИНФОРМАЦИИ

Теоретические основы ЭП

Асимметричное шифрование (открыто в 70-х годах прошлого века) основано на том факте, что некоторые математические операции являются односторонними, то есть по прямое и обратное преобразования сильно отличаются по сложности.

Зашифровываются данные одним ключом, а расшифровываются другим.

Ключи однозначно связаны между собой, но без дополнительной информации невозможно получить один из другого.

Один ключ называют **открытым**; он может свободно передаваться по открытым каналам, так как позволяет выполнить только половину криптопреобразования (либо только расшифровать, либо только зашифровать).

Второй – **закрытым**; он хранится в секрете владельцем.

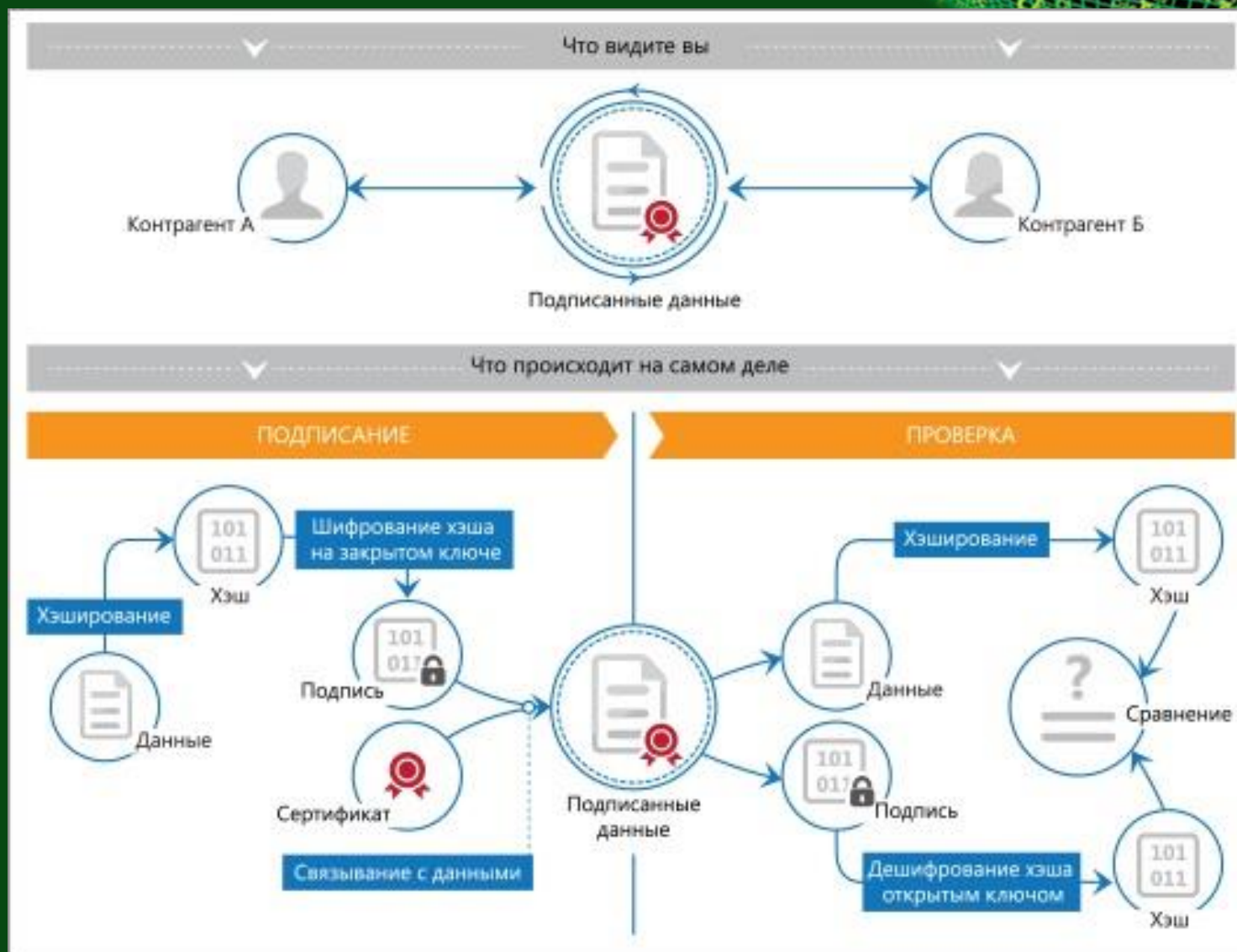


Федеральный закон от 06.04.2011 N 63-ФЗ
(ред. от 23.06.2016)
«Об электронной подписи»

Ранее действовал Федеральный закон от
10.01.2002 N 1-ФЗ
«Об электронной цифровой подписи»

Общие понятия

- *Электронная подпись (ЭП)* – это особый реквизит документа, который позволяет установить отсутствие искажения информации в электронном документе с момента формирования ЭП и подтвердить принадлежность ЭП владельцу. Значение реквизита получается в результате криптографического преобразования информации.
- *Сертификат электронной подписи* – документ, который подтверждает принадлежность открытого ключа (ключа проверки) ЭП владельцу сертификата. Выдаются сертификаты удостоверяющими центрами (УЦ) или их доверенными представителями.
- *Владелец сертификата ЭП* – физическое лицо, на чье имя выдан сертификат ЭП в удостоверяющем центре. У каждого владельца сертификата на руках два ключа ЭП: закрытый и открытый.
- *Закрытый ключ электронной подписи (ключ ЭП)* позволяет генерировать электронную подпись и подписывать электронный документ. Владелец сертификата обязан в тайне хранить свой закрытый ключ.
- *Открытый ключ электронной подписи (ключ проверки ЭП)* однозначно связан с закрытым ключом ЭП и предназначен для проверки подлинности ЭП.

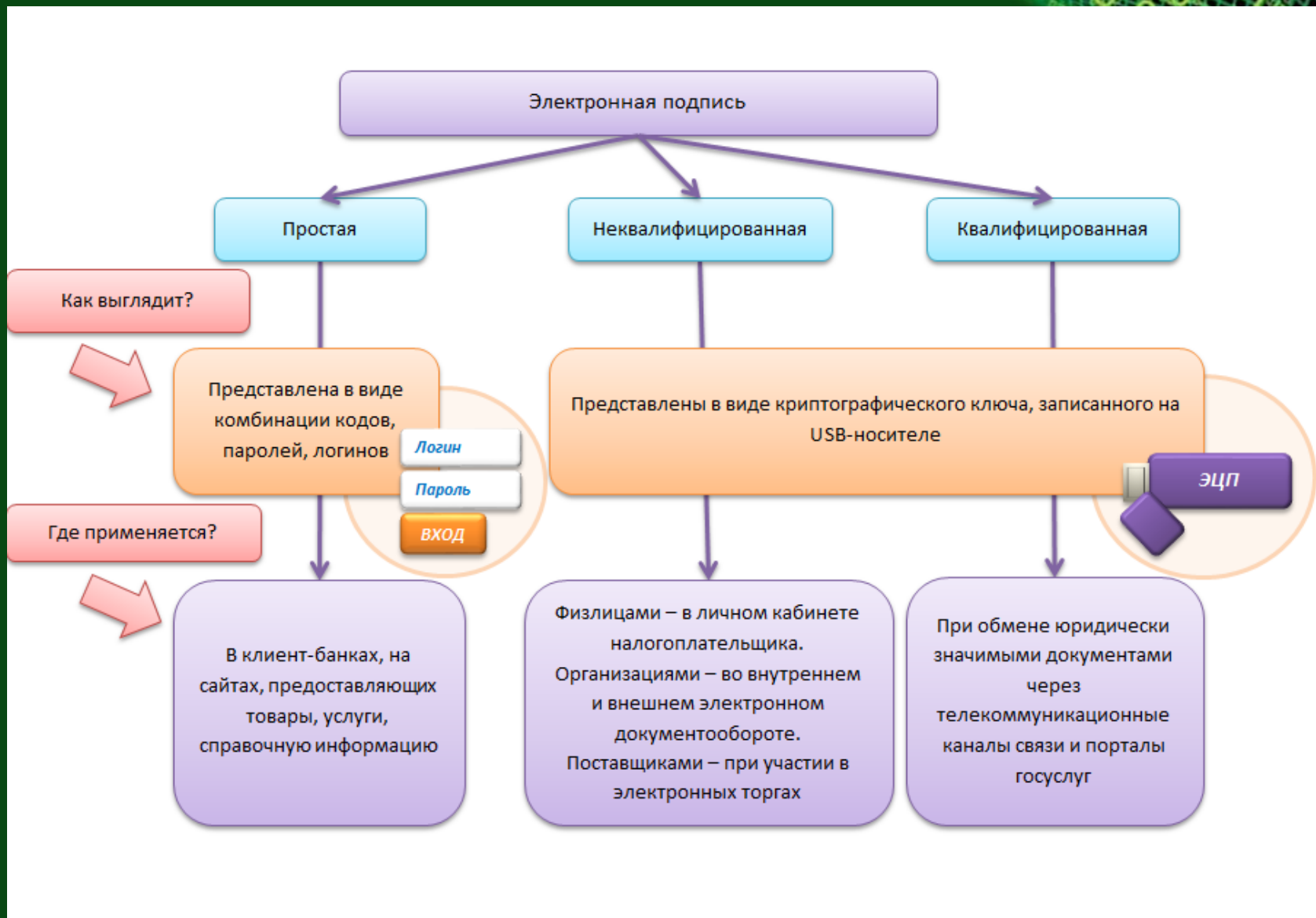


Хэширование или **хеширование** (англ. *hashing*) — преобразование массива входных данных произвольной длины в (выходную) битовую строку фиксированной длины, выполняемое определённым алгоритмом. Функция, реализующая алгоритм и выполняющая преобразование, называется «**хеш-функцией**» или «**функцией свёртки**». Исходные данные называются входным массивом, «**ключом**» или «**сообщением**». Результат преобразования (выходные данные) называется «**хешем**», «**хеш-кодом**», «**хеш-суммой**», «сводкой сообщения».

Виды ЭП

Федеральный закон №63-ФЗ «Об электронной подписи» выделяет:

- *Простая электронная подпись* посредством использования кодов, паролей или иных средств подтверждает факт формирования ЭП определенным лицом.
- *Усиленную неквалифицированную электронную подпись* получают в результате криптографического преобразования информации с использованием закрытого ключа подписи. Данная ЭП позволяет определить лицо, подписавшее электронный документ, и обнаружить факт внесения изменений после подписания электронных документов.
- *Усиленная квалифицированная электронная подпись* соответствует всем признакам неквалифицированной электронной подписи, но для создания и проверки ЭП используются средства криптозащиты, которые сертифицированы ФСБ РФ. Кроме того, сертификаты квалифицированной ЭП выдаются исключительно аккредитованными удостоверяющими центрами.



Юридическая значимость ЭП

- Согласно ФЗ № 63 «Об электронной подписи» электронный документ, подписанный простой или усиленной неквалифицированной ЭП, признается равнозначным документу на бумажном носителе, подписанному собственноручной подписью. При этом обязательным является соблюдение следующего условия: между участниками электронного взаимодействия должно быть заключено соответствующее соглашение.
- Усиленная квалифицированная подпись на электронном документе является аналогом собственноручной подписи и печати на бумажном документе. Контролирующие органы, такие как ФНС, ПФР, ФСС, признают юридическую силу только тех документов, которые подписаны квалифицированной ЭП.

ГОСТ Р 7.0.97-2016 «Организационно-распорядительная документация.
Требования к оформлению документов»
(утв. Приказом Росстандарта от 08.12.2016 N 2004-ст), вступающий в
силу с 01.07.2017, ввел реквизит «Отметка об электронной подписи»,
позволяющий визуализировать ЭП.

Контрольно-кассовая техника является автоматизированной системой для бланков строгой отчетности (да/нет) Нет

Контрольно-кассовая техника используется при продаже подакцизных товаров (да/нет) Нет

Обработку фискальных данных осуществляет Общество с ограниченной ответственностью "Эвотор ОФД", ИНН 9715260691

Количество перерегистраций контрольно-кассовой техники 0

Зарегистрирована в налоговом органе с 23.01.2017
(дата регистрации)



ДОКУМЕНТ ПОДПИСАН
УСИЛЕННОЙ КВАЛИФИЦИРОВАННОЙ
ЭЛЕКТРОННОЙ ПОДПИСЬЮ

Сертификат: 544310830208232854768134

Владелец: МИ ФНС России по ЦОД

Действителен: с 06.04.2016 до 06.04.2017

23.01.2017



ЗАЩИТА ИНФОРМАЦИИ ОТ ПОТЕРИ И РАЗРУШЕНИЯ

Причины потери информации



1) нарушение работы компьютера;



2) отключение или сбой питания;



3) повреждение носителей информации;



4) ошибочные действия пользователя;



5) действие компьютерных вирусов;



6) умышленные несанкционированные действия
посторонних.

Предотвращение потери информации

1. *Резервирование данных* (ПО для создания резервных копий, архивы на внешних носителях информации).
2. *Восстановление* (Undelete из пакета служебных программ DOS, Unerase из комплекта служебных программ Norton Utilities и т.п.)
3. *Защита от уничтожения:*
 - присвоить файлам свойство Read Only (только для чтения);
 - ПО для сохранения файлов после удаления, имитирующие удаление (защищенная корзина).
4. *Защита от нарушений в системе подачи электропитания* (источники бесперебойного питания).

Резервное копирование —

единственный эффективный способ
не допустить потери информации.

Варианты организации резервного
копирования:

- Внешние носители
- Облачные сервисы



ЗАЩИТА ИНФОРМАЦИИ ОТ НЕСАНКЦИОНИРОВАННОГО ДОСТУПА

- *Несанкционированный доступ (НСД)* – это чтение, изменение или разрушение информации при отсутствии на это соответствующих полномочий

Пути несанкционированного получения информации

- хищение носителей информации и производственных отходов;
- копирование носителей информации с преодолением мер защиты;
- маскировка под зарегистрированного пользователя;
- мистификация (маскировка под запросы системы);
- использование недостатков операционных систем и языков программирования;
- использование программных закладок и программных блоков типа "троянский конь";
- перехват электронных излучений;
- перехват акустических излучений;
- дистанционное фотографирование;
- применение подслушивающих устройств;
- злоумышленный вывод из строя механизмов защиты и т.д..

Принципы защиты от НСД

- Принцип обоснованности доступа
- Принцип достаточной глубины контроля доступа
- Принцип разграничения потоков информации
- Принцип персональной ответственности

Идентификация и аутентификация

Идентификация позволяет субъекту (пользователю, процессу) назвать себя (сообщить свое уникальное имя - идентификатор).

Посредством **аутентификации** вторая сторона убеждается, что субъект действительно тот, за кого он себя выдает. В качестве синонима слова **аутентификация** иногда используют словосочетание "проверка подлинности".

Методы аутентификации

- Парольная (пользователь «знает»)
- По предмету (пользователь «имеет»)
- Биометрические (пользователь «есть»)

Парольная аутентификация

+

- простота
- привычность

—

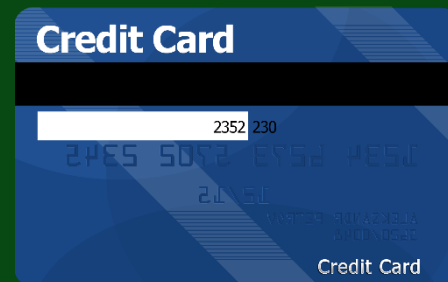
- Можно подсмотреть
- Можно угадать (взломать)
- Часто легче поделиться паролем, чем настраивать доступ нескольких пользователей

Повышение надежности парольной защиты

- *наложение технических ограничений;*
- *управление сроком действия паролей;*
- *ограничение доступа к файлу паролей;*
- *ограничение числа неудачных попыток
входа в систему;*
- *одноразовые пароли;*
- *опознавание в диалоговом режиме*

Аутентификация по предмету

- USB-токены
- пластиковые карты с чипом и/или магнитной полосой
- электронные таблетки iButton (или Touch Memory)



Биометрическая аутентификация

- К числу физиологических характеристик принадлежат особенности **отпечатков пальцев, сетчатки и роговицы глаз, геометрия руки и лица** и т.п.
- К поведенческим характеристикам относятся **динамика подписи (ручной), стиль работы с клавиатурой (клавиатурный почерк)**.
- На стыке физиологии и поведения находятся анализ особенностей **голоса** и **распознавание речи**.





ЗАЩИТА ИНФОРМАЦИИ ОТ УТЕЧКИ ПО ТЕХНИЧЕСКИМ КАНАЛАМ

Терминология

- Утечка информации – неконтролируемый выход конфиденциальных данных за границы защищаемой зоны
- Канал утечки (несанкционированного получения информации)



Классификация КНПИ по физической природе

- – визуально-оптические (непосредственное или удаленное наблюдение);
- – акустические (включая и акустико-преобразовательные);
- – электромагнитные (включая магнитные и электрические);
- – материально-вещественные (бумага, фото, магнитные носители, производственные отходы различного вида – твердые, жидкие, газообразные).

Визуально-оптические КНПИ



Видеть - значит различать
врага и друга и окружающее
во всех подробностях...

С. И. Вавилов.



Скрытая
миниатюрная
камера



и не только....

Акустические КНПИ



Электронный
стетоскоп



Радиозакладка



Остронаправленный
микрофон



Индукционное
подключение
к телефонной линии

Признаки прослушивания телефона



Слишком быстро
разряжается батарея



Иногда телефон без
причины перезагружается
или включается подсветка



Когда вы звоните,
соединение
устанавливается
слишком долго



Во время звонка вы
иногда слышите
посторонние голоса и звуки

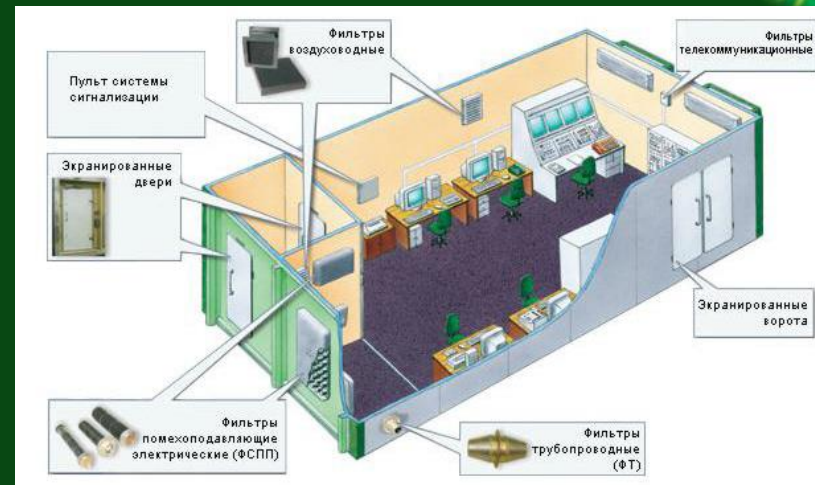


Когда вы подносите телефон
к колонкам, они начинают
издавать помехи, хотя
вам никто не звонит

Электромагнитные КНПИ

- Побочные электромагнитные излучения и наводки (ПЭМИН) возникают во время работы в выделенном помещении радиосредств и электрических приборов.
- Защита:
 - активная (электромагнитный шум)
 - пассивная (экранирование)
 - комбинированная

Устройства защиты от утечки по каналу ПЭМИН



Генератор шума
«Баррикада»



Маскиратор «Маис-М»



Материально-вещественные каналы утечки

- черновики различных документов и макеты материалов, узлов, блоков, устройств, разрабатываемых в ходе научно-исследовательских и опытно-конструкторских работ, ведущихся в организации;
- отходы делопроизводства и издательской деятельности в организации, в том числе использованная копировальная бумага, за бракованные листы при оформлении документов и их размножении;
- отходы промышленного производства опытного и серийного выпуска продукции, содержащей защищаемую информацию в газообразном, жидком и твердом виде;
- содержащие защищаемую информацию дискеты и жесткие диски ПЭВМ, нечитаемые из-за их физических дефектов и искажений загрузочных или других секторов;
- бракованная продукция и ее элементы;
- радиоактивные материалы.



ОРГАНИЗАЦИОННО-ПРАВОВЫЕ МЕРЫ ЗАЩИТЫ ИНФОРМАЦИИ

НОРМАТИВНО-ПРАВОВАЯ ОСНОВА КОНЦЕПЦИИ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ



Организационные меры защиты

- **Организационные меры защиты** – меры организационного характера, предназначенные для регламентации функционирования информационных систем, работы персонала, взаимодействия пользователей с системой.
- Среди базовых организационных мер *по* защите информации можно выделить следующее:
 - Формирование *политики безопасности*;
 - *Регламентация доступа* в помещения;
 - Регламентация допуска сотрудников к использованию ресурсов информационной системы и др.
 - Определение ответственности в случае несоблюдения требований информационной безопасности.

Основные организационные мероприятия

- – организация режима и охраны. Их цель – исключение возможности тайного проникновения на территорию и в помещения посторонних лиц; обеспечение удобства контроля прохода и перемещения сотрудников и посетителей; создание отдельных производственных зон по типу конфиденциальных работ с самостоятельными системами доступа; контроль и соблюдение временного режима труда и пребывания на территории персонала фирмы; организация и поддержание надежного пропускного режима и контроля сотрудников и посетителей и др.;
- – организация работы с сотрудниками, которая предусматривает подбор и расстановку персонала, включая ознакомление с сотрудниками, их изучение, обучение правилам работы с конфиденциальной информацией, ознакомление с мерами ответственности за нарушение правил защиты информации и др.;
- – организация работы с документами и документированной информацией, включая организацию разработки и использования документов и носителей конфиденциальной информации, их учет, исполнение, возврат, хранение и уничтожение;
- – организация использования технических средств сбора, обработки, накопления и хранения конфиденциальной информации;
- – организация работы по анализу внутренних и внешних угроз конфиденциальной информации и выработке мер по обеспечению ее защиты;
- – организация работы по проведению систематического контроля за работой персонала с конфиденциальной информацией, порядком учета, хранения и уничтожения документов и технических носителей.